

Plano de Implementação do Modelo RBAC

Plano de Implementação do Modelo RBAC baseado em Grupos de Segurança no Tenant Azure do PLANAPP

Para reorganizar o modelo RBAC do tenant Azure do PLANAPP será implementado um plano em fases de transição, substituindo as atribuições de *roles* individuais por *roles* atribuídas a **grupos de segurança do Microsoft Entra ID**, em conformidade com as recomendações do **Microsoft Cloud Adoption Framework (CAF)** e da arquitetura **Enterprise-Scale**. Este plano cobre **todo o tenant** (Management Groups, Subscrições e Resource Groups) e visa reduzir riscos, facilitar a administração e aumentar a conformidade com as políticas de governação já definidas para o ambiente Azure do PLANAPP.

Menor Privilégio e Segregação de Funções Garantir que cada utilizador tenha apenas os privilégios mínimos , segregando papéis e eliminando acessos individuais desnecessários.	Funções Atribuídas a Grupos, Não a Indivíduos Implementar grupos de segurança dedicados a cada função (ex.: Owner, Contributor) por domínio, substituindo progressivamente atribuições diretas a utilizadores.
Migração Faseada e Controlada Transição segura em fases, com coexistência temporária de roles diretos e via grupos para evitar interrupções , validação em ambiente menos crítico e previsão de rollback imediato se necessário.	

```
</style><div class="insights-container"><div class="insight-card"><h4>Menor Privilégio e Segregação de Funções</h4><p>Garantir que cada utilizador tenha <b>apenas os privilégios mínimos</b>, segregando papéis e eliminando acessos individuais desnecessários.</p></div><div class="insight-card"><h4>Funções Atribuídas a Grupos, Não a Indivíduos</h4><p>Implementar grupos de segurança <b>dedicados a cada função</b> (ex.: Owner, Contributor) por domínio, substituindo progressivamente atribuições diretas a utilizadores.</p></div><div class="insight-card"><h4>Migração Faseada e Controlada</h4><p>Transição segura em fases, com coexistência temporária de roles diretos e via grupos para <b>evitar interrupções</b>, validação em ambiente menos crítico e previsão de <b>rollback</b> imediato se necessário.</p></div></div>
```

Contexto Atual e Objetivos

Situação atual: O tenant Azure do PLANAPP conta com **6 Management Groups** e **9 subscrições** (com os domínios Plataforma, Landing Zones Produção/Não-Produção, Sandbox, Descontinuadas), dos quais **4 subscrições permanecem sob a raiz do tenant** – um *anti-padrão* identificado pela governação do CAF. Adicionalmente, as atribuições RBAC neste tenant são **maioritariamente feitas a utilizadores individuais**, em vez de grupos de segurança, resultando em **pouca clareza de proprietários** e **elevado esforço de administração**. Uma auditoria de conformidade evidenciou, por exemplo, que **91% dos resource groups não têm proprietário diretamente atribuído**. Esta situação acarreta riscos de segurança e dificulta o controlo de acessos, levando o PLANAPP a definir como meta a transição para um modelo de RBAC baseado em **grupos de segurança do Microsoft Entra ID**.

Objetivo do plano: Alinhar o modelo de gestão de acessos do tenant com as **boas práticas da Microsoft** de cloud governance, nomeadamente **princípios do least privilege** (privilégio mínimo necessário) e **atribuição de roles via grupos** em vez de utilizadores individuais. O plano visa **reduzir privilégios excessivos** e o **risco de erro humano**, agilizar o processo de **onboarding/offboarding** e suporte (as permissões passam a ser geridas por grupo, e não individualmente), e **fortalecer a segregação de funções** para melhor segurança e conformidade.

Princípios de Desenho RBAC

Os princípios orientadores para o modelo RBAC alvo são:

- **Princípio do menor privilégio:** Conceder a cada utilizador apenas as permissões **estritamente necessárias** para desempenhar as suas funções, evitando atribuições mais amplas do que o necessário. Isso requer **diferenciar papéis** (e.g. administração, desenvolvimento, auditoria) e garantir que ninguém detenha privilégios acima do indispensável, alinhando com uma cultura de **just enough access** e **segregação de funções** (não acumular diferentes privilégios críticos na mesma pessoa ou grupo). Quando apropriado, utilizar mecanismos de **Privileged Identity Management (PIM)** para acesso temporário (*just-in-time*) a *roles* críticas.
- **Atribuição de *roles* a grupos (e não a indivíduos):** Conforme as melhores práticas Azure, os *role assignments* devem ser feitos preferencialmente a **grupos de segurança** do Entra ID, em vez de a contas individuais. Este enfoque simplifica a gestão de acessos, reduz o número total de atribuições (evitando limites técnicos e complexidade) e diminui o risco de falhas de segurança decorrentes de erros humanos. Por exemplo, a **auditoria PLANAPP** recomendou explicitamente passar as atribuições de *Owner* para grupos de segurança dedicados, ao invés de utilizadores isolados.
- **Herança no nível mais alto possível:** Atribuir as funções (*roles*) sempre no **escalão hierárquico mais elevado** onde fizer sentido. Sempre que possível, utilizar *role assignments* ao nível de **Management Groups** ou **Subscrições** (e não a cada *resource group* isoladamente) para herdar permissões pelas estruturas inferiores. **Exemplo:** Atribuir um grupo de *Owners* a um **Management Group** faz com que esse acesso seja propagado de forma consistente a todas as subscrições e *resource groups* abaixo, simplificando a sua gestão e removendo a necessidade de duplicar atribuições em cada recurso individual. Este princípio deve ser equilibrado com o *least privilege*, ou seja, optar pelo escopo mais alto possível **mas que não conceda acessos desnecessários**.
- **Segregação de papéis e responsabilidades:** Definir **grupos de segurança distintos para cada tipo de papel** (e.g. *Owner*, *Contributor*, *Reader*), de modo a separar claramente funções administrativas, operacionais e de leitura. Isto previne cenários de concentração de privilégios e assegura **controlo de acessos granular e auditável**. O modelo de RBAC deve refletir as **funções organizacionais**: por exemplo, a equipa central de gestão da plataforma (**Equipa SITDIA**) deterá *roles* de *Owner/Contributor* em recursos de **Plataforma**, enquanto equipas de aplicações em **Landing Zones** deverão ter restrições (ex.: *Contributors* nos seus recursos de negócio, sem acesso ilimitado à plataforma).

Modelo Alvo de Grupos de Segurança e Estrutura de Roles

Com base nestes princípios, preconiza-se a **criação de grupos de segurança normalizados** no Entra ID para gerir as permissões do tenant PLANAPP. Estes grupos serão definidos por **domínio funcional** (Plataforma, LZ Produção, LZ Não-Produção, Sandbox) e por **nível de privilégio**. Cada grupo representará um mapeamento claro **Grupo ↔ Role ↔ Âmbito**, conforme exemplificado na tabela abaixo. Assim, cada grupo de segurança tem um **nome padronizado**, incorporando: o âmbito (*domain* Azure e/ou subscrição), o nível de privilégio (*role* atribuída) e, opcionalmente, o ambiente (quando aplicável). Por exemplo, poderíamos ter “az-pla-prd-owner” (grupo para Owners das Landing Zones de Produção) e “az-pla-nprd-contributor” (grupo para Contributors das Landing Zones de Não-Produção). A convenção recomendada é a seguinte:

- **Prefixo AZ-:** identifica grupos de segurança destinados a atribuição de *roles* Azure.
- **Código da entidade:** `p1a` (identifica PLANAPP, em conformidade com a política de nomenclaturas v2.0).
- **Código do domínio e/ou ambiente:** `platform` (plataforma compartilhada), `prd` (produção), `nprd` (não-produção), `sandbox` (laboratórios).
- **Papel de RBAC:** `owner` (controle total no âmbito), `contributor` (gestão de recursos sem controlo de acesso), `reader` (apenas leitura), etc.

Matriz de RBAC por Domínio: Nos quadros seguintes apresenta-se a distribuição proposta de grupos de segurança e as respetivas *role assignments* (papéis e âmbitos) para cada um dos domínios do tenant Azure do PLANAPP — **Plataforma**, **Landing Zones de Produção**, **Landing Zones de Não-Produção** e **Sandbox**. Este modelo cobre também a segregação por ambiente (produção e não-produção), conforme definido na arquitetura de *landing zones* do CAF, reflectindo a estrutura de *Management Groups* e subscrições atualmente planeada.

Domínio Plataforma (Management Group mg-planapp-platform)

Os recursos de **Plataforma** (rede *hub*, *backups*, *governança de dados*, *analytics*, etc.) são geridos centralmente pela equipa de **Plataforma/Sistemas de Informação**. Assim, os papéis de **Owner** e **Contributor** neste domínio ficam maioritariamente restritos à equipa central (SITDIA). Podem ser definidos grupos de leitura global para outras equipas (ex.: *Security Readers* ou *Auditores*).

	≡ Role (Azure RBAC)	≡ Grupo de Segurança (Entra ID)	≡ Âmbito de Assignment	≡ Observações principais
1	Owner @ mg-planapp-platform	az-pla-platform-owner	MG “Plataforma” (<i>herdado</i> pela(s) subscrição(ões) de plataforma)	Equipa central (SITDIA) tem controlo total da plataforma. Permite gerir <i>policies</i> , <i>rede</i> e recursos partilhados.
2	Contributor @ mg-planapp-platform	az-pla-platform-contrib	MG “Plataforma” (<i>herdado</i> pela(s) subscrição(ões) de plataforma)	Equipa de operação de infraestrutura (e.g. parceiros externos ou administradores de rede) com permissão de gestão operacional sem acesso a <i>IAM</i> .
3	Reader @ mg-planapp-platform	az-pla-platform-reader	MG “Plataforma” (<i>herdado</i> pela(s) subscrição(ões) de plataforma)	Grupo para equipa de segurança (e.g. Security/Cloud Governance) com visibilidade de leitura total (RBAC Security Reader), para auditorias de risco.

Domínio Landing Zones de Produção (Management Group mg-planapp-lz-prod)

Este domínio abrange as subscrições que alojam **workloads de produção** (aplicações e dados em ambiente produtivo). As equipas de desenvolvimento e operação das aplicações terão acesso *Contributor* ou *Reader* conforme suas funções, enquanto a equipa central de IT/Governança mantém o controlo de *Owner* para garantir conformidade e suporte. No futuro, caso haja múltiplas subscrições de produção com equipas independentes, poderão ser criados **subgrupos** por subscrição, mas numa primeira fase recomenda-se centralizar o modelo ao nível do *Management Group* de produção, para simplificar.

	≡ Role (Azure RBAC)	≡ Grupo de Segurança (Entra ID)	≡ Âmbito de Assignment	≡ Observações principais
1	Owner @ mg-planapp-lz-prod	az-pla-prd-owner	MG “LZ Produção” (<i>herdado</i> por todas as subscrições Prod)	Equipa central (SITDIA) com controlo total (garantia de supervisão e gestão de RBAC/políticas nas LZ de produção).
2	Contributor @ mg-planapp-lz-prod	az-pla-prd-contrib	MG “LZ Produção” (<i>herdado</i> por todas as subscrições Prod)	Equipa(s) de desenvolvimento/gestão de aplicações em produção com poderes para criar e gerir recursos das suas <i>workloads</i> de negócio. Sem privilégio de controlo de acesso.

3	Reader @ mg-planapp-lz-prod	az-pla-prd-reader	MG "LZ Produção" (<i>herdado</i> por todas as subscrições Prod)	Equipa(s) de suporte, auditores e segurança com visibilidade de dados e configurações das cargas de trabalho de produção.
---	-----------------------------	-------------------	---	---

Domínio Landing Zones de Não-Produção (Management Group mg-planapp-lz-nprd)

Este domínio reúne as subscrições e *workloads* de **Desenvolvimento, Teste e Qualidade**, onde os requisitos de segurança e **restrições de política** são menos estritos do que em produção. O modelo RBAC espelha o de produção, com grupos dedicados para cada papel, permitindo flexibilidade para as equipas técnicas de desenvolvimento/testes atuarem com maior liberdade, mas ainda sob governação central.

	≡ Role (Azure RBAC)	≡ Grupo de Segurança (Entra ID)	≡ Âmbito de Assignment	≡ Observações principais
1	Owner @ mg-planapp-lz-nprd	az-pla-nprd-owner	MG "LZ Não-Produção" (<i>herdado</i> pelas subscrições Não-Prod)	Equipa central (SITDIA) com controlo total (governação global das LZ de não-produção).
2	Contributor @ mg-planapp-lz-nprd	az-pla-nprd-contrib	MG "LZ Não-Produção" (<i>herdado</i> pelas subscrições Não-Prod)	Equipa de Dev/Test das aplicações com permissão de gerir os recursos das suas <i>workloads</i> não produtivas, respeitando políticas de restrição (e.g. não utilização de dados reais em dev/test).
3	Reader @ mg-planapp-lz-nprd	az-pla-nprd-reader	MG "LZ Não-Produção" (<i>herdado</i> pelas subscrições Não-Prod)	Equipa(s) de suporte, QA e auditoria para acompanhar testes e <i>deployments</i> .

Domínio Sandbox (Management Group mg-planapp-sandbox)

O domínio **Sandbox** destina-se a **experimentação isolada e de curta duração**. Graças às políticas de custeio e expiração definidas a nível do *Management Group* Sandbox, este ambiente permanece controlado. No modelo RBAC, a equipa central mantém controlo global e as equipas que utilizam os laboratórios têm permissões de contributo limitadas ao *scope* Sandbox, promovendo autonomia para experimentar com baixo risco.

	≡ Role (Azure RBAC)	≡ Grupo de Segurança (Entra ID)	≡ Âmbito de Assignment	≡ Observações principais
1	Owner @ mg-planapp-sandbox	az-pla-sandbox-owner	MG "Sandbox" (<i>herdado</i> pela subscrição de Sandbox)	Equipa central (SITDIA) com acesso total (garantindo supervisão e controlo do ciclo de vida dos recursos temporários).

2	Contributor @ mg-planapp-sandbox	az-pla-sandbox-contrib	MG "Sandbox" (herdado pela subscrição de Sandbox)	Equipa(s) de experimentação (desenvolvedores ou investigadores) com total capacidade de criar e gerir recursos nas suas sandboxes, respeitando limites de custo e <i>políticas</i> de auto-expiração de recursos.
3	Reader @ mg-planapp-sandbox	(se necessário, ex.: "az-pla-sandbox-reader")	MG "Sandbox" (herdado pela subscrição de Sandbox)	Poderá não ser necessário; caso haja interesse de outras equipas em visualizar <i>pilotos</i> na Sandbox, concede visibilidade de leitura.

Fases de Implementação do Novo Modelo RBAC

Para alcançar o modelo acima delineado, será seguido um **plano de implementação faseado** que minimize interrupções e assegure a **transição segura** para o novo modelo RBAC baseado em grupos:

Fase 1: Descoberta e Inventário (Semana 1-2)

Levantamento completo das atuais atribuições RBAC: extrair todas as *role assignments* do tenant PLANAPP para identificar **quem tem acesso a quê**. Este inventário deverá mapear **perfis** (utilizador ou *service principal*), **tipo de papel atribuído** (e.g. Owner, Contributor, etc.) e **nível de âmbito** (MG, Subscrição ou *Resource Group*) de todas as entradas existentes.

Fase 2: Desenho do Modelo Alvo (Semana 2-3)

Com base no levantamento, **desenhar a matriz RBAC alvo**: definir os grupos de segurança a criar (conforme a estrutura apresentada acima) e a correspondência de cada grupo a um *role* e a um determinado âmbito (MG/Subscrição/RG). Definir **nova matriz de acessos** por domínio (conforme tabelas anteriores), assegurando conformidade com os princípios de desenho RBAC.

Fase 3: Configuração dos Grupos de Segurança (Semana 3-4)

Criar os grupos no Entra ID segundo as convenções definidas (naming conventions) e **popular os grupos** com os utilizadores adequados de acordo com as suas funções atuais. Esta etapa pode envolver a colaboração com as equipas de RH/gestão de utilizadores para garantir que a associação de utilizadores a cada grupo **reflete os seus papéis operacionais**.

Fase 4: Migração Faseada dos Acessos (Semana 5-8)

Atribuir os grupos criados aos respetivos papéis em Azure: começar pelos âmbitos menos críticos (e.g., **Sandbox e Não-Produção**), aplicando os *role assignments* conforme a matriz definida (p. ex., associar o grupo "az-pla-nprd-contrib" como *Contributor* no MG Não-Produção). **Manter temporariamente as atribuições antigas** (utilizadores individuais) em simultâneo, de forma a garantir que não há perda de acesso durante a transição.

Fase 5: Validação e Ajustes (Semana 6-8)

```
</style><ul class="timeline-container"><li><h4>Fase 1: Descoberta e Inventário (Semana 1-2)</h4><p>Levantamento completo das atuais atribuições RBAC: extrair todas as <i>role assignments</i> do tenant PLANAPP para identificar <b>quem tem acesso a quê</b>. Este inventário deverá mapear <b>perfis</b> (utilizador ou <i>service principal</i>), <b>tipo de papel atribuído</b> (e.g. Owner, Contributor, etc.) e <b>nível de âmbito</b> (MG, Subscrição ou <i>Resource Group</i>) de todas as
```

entradas existentes.

- #### Fase 2: Desenho do Modelo Alvo (Semana 2-3)

Com base no levantamento, desenhar a matriz RBAC alvo: definir os grupos de segurança a criar (conforme a estrutura apresentada acima) e a correspondência de cada grupo a um <i>role</i> e a um determinado âmbito (MG/Subscrição/RG). Definir nova matriz de acessos por domínio (conforme tabelas anteriores), assegurando conformidade com os princípios de desenho RBAC.
- #### Fase 3: Configuração dos Grupos de Segurança (Semana 3-4)

Criar os grupos no Entra ID segundo as convenções definidas (*naming conventions*) e popular os grupos com os utilizadores adequados de acordo com as suas funções atuais. Esta etapa pode envolver a colaboração com as equipas de RH/gestão de utilizadores para garantir que a associação de utilizadores a cada grupo reflete os seus papéis operacionais.
- #### Fase 4: Migração Faseada dos Acessos (Semana 5-8)

Atribuir os grupos criados aos respetivos papéis em Azure: começar pelos âmbitos menos críticos (e.g., Sandbox e Não-Produção), aplicando os <i>role assignments</i> conforme a matriz definida (p. ex., associar o grupo “az-pla-nprd-contrib” como <i>Contributor</i> no MG Não-Produção). Manter temporariamente as atribuições antigas (utilizadores individuais) em simultâneo, de forma a garantir que não há perda de acesso durante a transição.
- #### Fase 5: Validação e Ajustes (Semana 6-8)

Testar exaustivamente os novos grupos e roles em cada domínio: verificar que todos os membros dos grupos conseguem desempenhar as suas funções e que não possuem privilégios indevidos. Corrigir eventuais lacunas (e.g., adicionar utilizadores em falta a grupos, ou criar grupos suplementares se necessário). Uma vez validado o funcionamento no âmbito de Não-Produção/Sandbox, repetir a migração progressivamente nos domínios de Plataforma e Produção, novamente com coabitação temporária dos acessos antigos e testes rigorosos antes do corte definitivo.
- #### Fase 6: Remoção de Atribuições Individuais (Semana 9)

Após confirmada a equivalência e eficácia dos grupos (em todas as áreas, incluindo Produção), remover as <i>role assignments</i> diretas atribuídas a utilizadores individuais. A partir deste momento, todas as permissões são geridas exclusivamente via grupos de segurança do Entra ID.

Notas de transição segura: Durante a migração faseada (Fase 4-6), adotar uma **estratégia de coexistência e rollback seguro**: manter temporariamente os acessos individuais paralelamente aos acessos por grupo até à validação final, garantindo que **nenhum utilizador perde acesso** no interim. Para possibilitar **reversão rápida**, reservar contas de emergência (*break-glass accounts*) com privilégios globais ou manter cópias de segurança das atribuições antigas, permitindo retroceder alterações caso alguma equipa fique indevidamente bloqueada.

Recomendações Operacionais e Governação Contínua

A transição para *RBAC* baseado em grupos deve vir acompanhada de **práticas operacionais** para manter o modelo robusto e sustentável:

- Onboarding e Offboarding integrados:** Atualizar os processos de **integração e desligamento de colaboradores** para incluir a manutenção da pertença a grupos de segurança apropriados. Por exemplo, um novo elemento de uma equipa de desenvolvimento **ingressa automaticamente** nos grupos de *Contributor* (e *Reader*) das respetivas subscrições do seu projeto, enquanto que um colaborador que sai da organização ou muda de função **é removido** dos grupos RBAC correspondentes no momento de saída. Isto previne acumulação de acessos obsoletos e garante que **ninguém mantém privilégios indevidos** após abandonar uma função.
- Controlo de privilégios elevados via PIM:** Para roles altamente sensíveis (e.g. *Owner* em escopos amplos e papéis de administração global), recomenda-se **Microsoft Entra Privileged Identity Management (PIM)** para promover *just-in-time access*, ou seja, que os membros dos grupos de *Owner* **ativem os privilégios apenas quando necessário** e por períodos limitados. Isto mitiga o risco de exposição prolongada de contas com privilégio elevado e **reduz a superfície de ataque**.
- Auditorias e revisões periódicas de acessos:** Implementar um ciclo de **revisão de acessos** (por exemplo **trimestral ou semestral**), envolvendo os responsáveis de cada área. Nesta revisão, verificar os membros de cada grupo RBAC e confirmar se todos os acessos continuam **adequados e justificados**. Qualquer desvio (ex.: utilizador num grupo de *Owner* sem necessidade) deve ser corrigido prontamente. Este procedimento assegura **conformidade contínua** e pode ser alinhado com revisões mais amplas de segurança ou auditorias internas.
- Automação e IaC:** Sempre que possível, **codificar e automatizar a gestão de RBAC e grupos**. Utilizar ferramentas de **Infraestrutura como Código (IaC)** (Bicep/Terraform) ou *scripts* do Azure PowerShell/CLI para definir e aplicar as

atribuições de roles, e **automatizar a criação de grupos** no Entra ID conforme padrões. Isso garante reprodutibilidade e **evita configurações manuais** sujeitas a falha humana. Por exemplo, um processo de *subscription vending* ou *landing zone automation* pode ser ajustado para já incluir a **criação de grupos RBAC e atribuições correspondentes** sempre que é provisionada uma nova subscrição ou ambiente.

- **Proteção e monitorização dos grupos RBAC:** Configurar os **grupos críticos como *role-assignable*** (propriedade `isAssignableToRole = True`), garantindo que apenas administradores globais ou de funções privilegiadas podem gerir a sua afiliação. Isto impede alterações não autorizadas na composição dos grupos com maiores privilégios. Além disso, ativar alertas (via Azure Monitor ou *scripts*) para **monitorizar eventuais alterações nos *role assignments*** ou nos próprios grupos (e.g., entrada/saída de membros), desencadeando notificações para a equipa de segurança/GSI em caso de mudanças significativas. Essa vigilância contínua ajuda a **deter e detetar rapidamente acessos indevidos**.

Riscos Comuns e Mitigações

Apesar das vantagens, a transição para RBAC baseado em grupos de segurança requer atenção a alguns **riscos potenciais**, com **ações de mitigação** adequadas:

- **Risco (escopo excessivo): Grupos atribuídos em escopos demasiado amplos** podem dar a utilizadores acesso a recursos que não necessitam, contrariando o princípio do menor privilégio. *Mitigação:* **Rever os limites de âmbito dos grupos** durante a fase de desenho; quando necessário, criar grupos mais granulares (por ex., grupos de *Contributor* por subscrição ou *resource group* específico) para restringir acessos sem comprometer a herança de permissões. Garantir que nenhum grupo recebe um role em nível superior ao efetivamente requerido.
- **Risco (falhas na transição): Interrupção de atividades** durante a migração, caso algum utilizador crítico não seja adicionado ao novo grupo ou ocorram conflitos de acesso. *Mitigação:* **Aplicar a migração em fases com sobreposição** de acessos antigos e novos (conforme previsto no plano); realizar **testes** de acesso com cenários de uso reais em cada etapa; e manter **plano de *rollback*** (acessos de emergência ou backup das configurações antigas) caso seja necessário reverter rapidamente alterações.
- **Risco (gestão de grupos e membros): Erros na administração dos grupos** (ex.: adicionar um membro indevido a um grupo privilegiado, ou não remover atempadamente um elemento que saiu da organização). *Mitigação:* **Restringir a gestão de afiliação** destes grupos a um número limitado de administradores de confiança; implementar **fluxos de aprovação** para alterações de membros; e **integrar o ciclo de vida de acessos aos processos de RH** (contratação/mudança/saída) para que as atualizações sejam automáticas e auditáveis.
- **Risco (utilizadores não corporativos): *Service principals* ou contas externas (B2B) com acessos diretos** podem ser negligenciados na transição e manter privilégios desnecessários. *Mitigação:* **Incluir todas as identidades de serviço ou externas** no inventário inicial; prever grupos dedicados para *workloads* e **contas de serviço** (ex.: *Service Principals* de aplicações), segregando-as de grupos de utilizadores humanos. Rever periodicamente estes acessos em conjunto com as equipas responsáveis pelas aplicações integradas.

Conclusão: A adoção de um modelo RBAC baseado em grupos de segurança permitirá ao PLANAPP **reduzir a superfície de risco** e melhorar a governança dos acessos em Azure, facilitando tanto a **gestão operacional** (menos atribuições repetitivas e centralização de permissões) quanto o **cumprimento das políticas de segurança e *compliance*** definidas. O plano proposto, **alinhado com o Microsoft CAF e Enterprise-Scale**, assegura uma **transição controlada**, minimizando impactos para as equipas e garantindo que, **após a conclusão da migração, 100% das permissões estarão atribuídas a grupos de segurança** e implementadas ao nível hierárquico apropriado. Esta reorganização reforçará a maturidade da governação de identidade e acessos no tenant Azure do PLANAPP, preparando o ambiente para escalabilidade futura com **maior segurança e eficiência operacional**.

